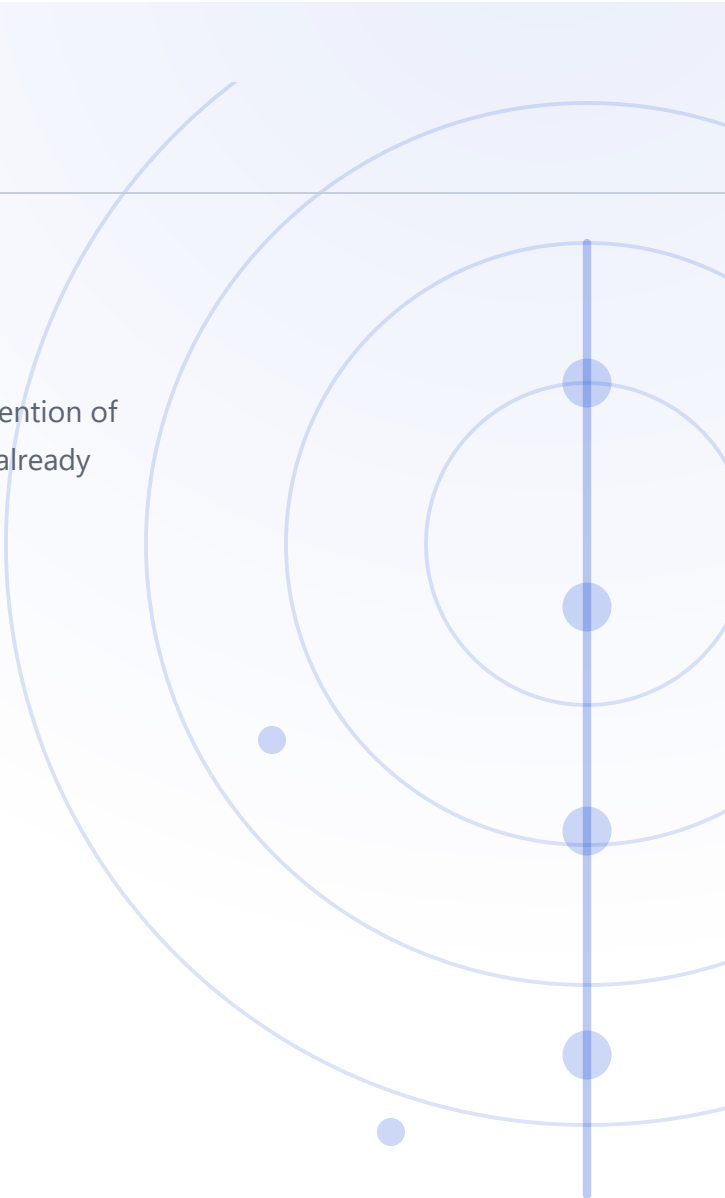


TLP: CLEAR

CAMPAIGN ANALYSIS G1030

# Agrius.

A destruction crew that sends a ransom note it has no intention of honouring — by the time the demand arrives the data is already unrecoverable, and paying buys nothing.



ASSESSED SEVERITYHigh

|                                        |                                   |                                                             |
|----------------------------------------|-----------------------------------|-------------------------------------------------------------|
| SUBJECT TYPE<br>Campaign · actor + CVE | ATTRIBUTION<br>Iran · MOIS-linked | FIRST OBSERVED<br>2020                                      |
| REPORT DATE<br>17 August 2026          | IS ACTIVE?<br>Yes                 | ALSO TRACKED AS<br>Pink Sandstorm · AMERICIUM · BlackShadow |

---

# EXECUTIVE SUMMARY

---

Agrius is an Iranian state-aligned crew that has been destroying data in the Middle East since 2020 while dressing the result up as ransomware. Victims receive a demand, but the files are already unrecoverable and no key exists — the payment request is cover for sabotage. It gets in through internet-facing edge devices, most often a FortiOS SSL VPN flaw that was patched two years before the group started using it, then steals data, kills the endpoint protection from kernel mode, and wipes.

**Route this to recovery, not to negotiation.** The single most expensive mistake available here is treating the ransom note as genuine. Hours spent waiting on a decryptor are hours not spent restoring, and the decryptor is never coming — early Apostle builds could not even destroy files reliably, let alone reverse the damage.

**Your sector ranking inverts against this actor.** Government and energy sit at critical while healthcare sits at low — the opposite of a criminal ransomware crew. Selection is on geopolitical value, not ability to pay, so the usual "we're a rich target" reasoning gives the wrong answer in both directions.

**One patched CVE is the whole documented front door.** CVE-2018-13379 was fixed years before these campaigns. Part 2's handoff line shows exactly how little of the intrusion that patch addresses — but it is the one step on the page a defender can close outright today.

**Backups are attacked as part of the operation, not incidentally.** Data is stolen before destruction, so a clean restore ends the outage without ending the incident. Offline copies and a leak-response plan are two separate requirements and this actor triggers both.

**Geography stopped being a filter in December 2022.** The diamond-industry intrusions reached South Africa and Hong Kong. Any exposure assessment resting on "we are not in Israel" needs replacing with one resting on what you expose to the internet.

## The ransom note is the disguise

Agrius is an Iranian threat actor active since **2020**, known for ransomware and wiper operations across the Middle East with a heavy emphasis on Israeli targets. Public reporting links the group to Iran's Ministry of Intelligence and Security. [1](#) [3](#)

The defining characteristic is that **the ransomware is cover**. Victims receive a ransom note, but the data has already been destroyed — payment recovers nothing. Treating an Agrius incident as an extortion event rather than a destructive one leads defenders to the wrong response: negotiating for a key that was never generated, instead of moving immediately to recovery. [3](#)

Across its campaigns the group's documented tradecraft is consistent: entry through internet-facing applications, ASPXSpy web shells relaying commands to `cmd.exe`, the IPsec Helper backdoor registered as a Windows service, Plink renamed to `systems.exe` for tunnelling, the vulnerable `GMER64.sys` driver loaded to terminate EDR from kernel mode, Mimikatz against LSASS and the SAM hive, WinEggDrop and NBTscan for internal discovery, RDP tunnelled through web shells for lateral movement, 7zip archives staged in `C:\windows\temp\s\`, and exfiltration over PuTTY and WinSCP before the wipers run. [1](#) [3](#)

## Activity, oldest first

2020

### First observed operating against Israeli targets

Researchers began tracking the group as a distinct cluster operating in Israel. Initial access was achieved by exploiting internet-facing applications, including **CVE-2018-13379** in FortiOS SSL VPN and SQL injection against web applications, with operator traffic routed through commercial VPN services to obscure origin. [1](#) [2](#) [3](#)

2020-11

### Apostle wiper developed

The Apostle wiper was built around November 2020. Early builds frequently failed to destroy files, so the group fell back to the DEADWOOD wiper to complete intrusions — an operational tell that destruction, not encryption, was the objective from the outset. [3](#)

2020-12

## Shirbit insurance targeted

The Israeli insurance company Shirbit was struck in a destructive operation presented publicly as a ransomware incident, following the group's pattern of data theft ahead of destruction. [3](#)

2021

## Bar-Ilan University and the IPsec Helper backdoor

Agrius targeted Bar-Ilan University, deploying the Apostle wiper alongside a custom .NET backdoor tracked as IPsec Helper, which was registered as a Windows service for persistence. Apostle was progressively reworked from a failing wiper into functional ransomware. [1](#) [3](#)

2022-12

## Diamond industry intrusions

The group was attributed to attempted disruptive intrusions against diamond industry organisations in **South Africa, Israel and Hong Kong**, marking the first widely reported expansion of targeting beyond Israel. [4](#) [5](#)

2023-05

## Moneybird ransomware deployed

A new ransomware strain written in C++ and tracked as Moneybird was deployed against Israeli organisations. Unlike the .NET-based Apostle, Moneybird represented a deliberate rewrite, indicating sustained tooling investment rather than opportunistic reuse. [4](#) [5](#)

# A destructive operation wearing a criminal costume

Three years of reporting describe an operation that looks like eCrime and behaves like sabotage. The ransom notes, the leak-site conventions and the ransomware branding all point at a financially motivated crew; the wiper development history, the state attribution and the choice of victims point somewhere else entirely. The gap between those two readings is the single most consequential thing about this actor, because it determines whether an incident response team spends its first hours negotiating or restoring.

- 1 A ransom note from Agrius is misdirection.** The data is already gone when the demand arrives. Any playbook that routes this to negotiation, or waits on a decryptor, is spending the most valuable hours of the response on an outcome that cannot happen.
- 2 Recovery capability is the control that matters, not decryption.** There is no key to buy. Tested, offline restores are the difference between an outage and a permanent loss — and the group steals data before destroying it, so restoring does not end the incident either.
- 3 The documented way in is a flaw patched years before it was used.** CVE-2018-13379 was disclosed and fixed long before these campaigns. This is an exposure-management failure rather than a zero-day problem, which makes it one of the few things on this page a defender can close outright.
- 4 Wiper failure drove tool investment, not retreat.** Apostle's early builds could not destroy files, so DEADWOOD covered the gap and Apostle was reworked; Moneybird was later a deliberate C++ rewrite. A group that re-engineers after failure is not opportunistic and will not be deterred by one closed door.
- 5 Geography stopped being a reliable filter in December 2022.** The diamond-industry intrusions reached South Africa and Hong Kong. Organisations that previously judged their exposure by not being in Israel need a different test.

# Who this actor actually hits

Agrius selects on geopolitical value rather than on what a victim can pay. The levels below track where victims have actually been observed, which is why sectors that would rank high against a financially motivated crew rank low here.

|                             |                                                                    |          |                                                                                                              |
|-----------------------------|--------------------------------------------------------------------|----------|--------------------------------------------------------------------------------------------------------------|
| Government                  | <div><div></div><div></div><div></div><div></div><div></div></div> | CRITICAL | Israeli government bodies are the stated focus of repeated destructive operations.                           |
| Energy and utilities        | <div><div></div><div></div><div></div><div></div><div></div></div> | CRITICAL | Targeted in destructive operations where the objective was disruption rather than revenue.                   |
| Manufacturing and logistics | <div><div></div><div></div><div></div><div></div><div></div></div> | HIGH     | The December 2022 diamond-industry intrusions show targeting extends to high-value commercial supply chains. |
| Financial services          | <div><div></div><div></div><div></div><div></div><div></div></div> | HIGH     | The Shirbit insurance incident places financial services inside the observed victim set.                     |
| Healthcare                  | <div><div></div><div></div><div></div><div></div><div></div></div> | LOW      | Outside the documented targeting; no reporting places Agrius in this sector.                                 |
| Retail and hospitality      | <div><div></div><div></div><div></div><div></div><div></div></div> | MINIMAL  | No indication of interest. Low geopolitical value to a state-aligned destructive actor.                      |

Critical — actively targeted

High — fits the victim profile

Moderate — plausible, not observed

Low — outside the pattern

Minimal — no indication

**Bottom line.** Exposure to Agrius is decided by geopolitical alignment and by what you expose to the internet — not by how much you could afford to pay. That inverts the usual ransomware calculation: a well-funded retailer is a poor target here, while a modestly resourced utility with an unpatched edge appliance is a good one. Healthcare sits low on this table for the same reason it would sit high against a criminal crew.

For *how* a compromise actually unfolds — the techniques, the tooling and the order they run in — see the companion attack-flow report.

# What this analysis is built on

- 1 MITRE ATT&CK — Groups: Agrius (G1030) — <https://attack.mitre.org/groups/G1030/>
- 2 NVD — CVE-2018-13379 (Fortinet FortiOS SSL VPN path traversal) — <https://nvd.nist.gov/vuln/detail/CVE-2018-13379>
- 3 SentinelOne SentinelLabs — From Wiper to Ransomware: The Evolution of Agrius — <https://www.sentinelone.com/labs/from-wiper-to-ransomware-the-evolution-of-agrius/>
- 4 Check Point Research — Agrius Deploys Moneybird in Targeted Attacks Against Israeli Organizations — <https://research.checkpoint.com/2023/agrius-deploys-moneybird-in-targeted-attacks-against-israeli-organizations/>
- 5 The Hacker News — Iranian Agrius Hackers Targeting Israeli Organizations — <https://thehackernews.com/2023/05/iranian-agrius-hackers-targeting.html>



**Confidence and sourcing.** The chronology, tooling and victimology are drawn from vendor and government reporting and are stated as reported. Attribution to Iran's Ministry of Intelligence and Security rests on published vendor assessment and is an *assessed* link rather than an established fact; the wording throughout keeps that distinction. Source 5 is a corroborating news outlet reporting the vendor research at source 4, and carries timeline and reach only — it is not an independent basis for the attribution claim. Sector risk levels are analyst assessments, not measured values; they deliberately share a colour ramp with CVSS severity but are rendered as meters rather than scores so the two are not confused.

# ATT&CK attack flow

How a compromise unfolds, tactic by tactic and in order. Part 1 established who is at risk and why; this part is how they get hit.

CAMPAIGN FLOW **G1030** · **CVE-2018-13379**

## Agrius.

An Iranian destruction crew walking through a **2018 Fortinet flaw** that hands out VPN credentials to anyone who asks. The vulnerability buys them the front door and nothing else — every wiper, web shell and killed EDR agent downstream is Agrius tradecraft that would work identically from any other foothold.

ALSO TRACKED AS

Pink Sandstorm

AMERICIUM

Agonizing Serpens

BlackShadow

EXPLOITS

**CVE-2018-13379**

|                                          |                             |                                   |
|------------------------------------------|-----------------------------|-----------------------------------|
| ATTRIBUTION<br><b>Iran · MOIS-linked</b> | ACTIVE SINCE<br><b>2020</b> | OBJECTIVE<br><b>Destruction</b>   |
| ENTRY VECTOR<br><b>FortiOS SSL VPN</b>   | CVSS<br><b>9.8 Critical</b> | CISA KEY<br><b>Since Nov 2021</b> |

# A path traversal that gives away credentials

One CVE, and an old one. Its value to Agrius is not code execution — it is that an unauthenticated request retrieves files from the SSL VPN appliance, and those files contain the credentials needed to log in as a legitimate user.

| CVE            | CVSS | EXPLOITATION | CWE    | WHAT IT GIVES THE ACTOR                                                                                              |
|----------------|------|--------------|--------|----------------------------------------------------------------------------------------------------------------------|
| CVE-2018-13379 | 9.8  | KEV          | CWE-22 | Unauthenticated file read on the FortiOS / FortiProxy SSL VPN portal, yielding VPN credentials rather than execution |

**What patching buys you.** It closes *one* of Agrius's documented entry routes. MITRE's own wording is worth reading carefully: initial access "examples include widespread attempts to exploit CVE-2018-13379 in FortiOS devices **and SQL injection activity**." Two named routes, presented as examples rather than an exhaustive list. A patched FortiOS estate is not an Agrius-proof estate.

**What it does not.** Nothing below phase 02 of the flow. The ASPXSpy web shells, the vulnerable-driver EDR kill, Mimikatz, the lateral movement and the wipers are all indifferent to how Agrius got in. Patch to close the door; hunt because the door may already have been used.

**The age is the story.** Fortinet fixed this in 2018 and CISA set a federal remediation deadline of May 2022, yet it remained a viable mass-exploitation route well beyond both. Internet-facing security appliances are routinely the least-patched infrastructure an organisation owns, and Agrius scanned for exactly that.

# One phase of vulnerability, ten of tradecraft

The CVE tag appears once and then stops. Where it stops is the point of this page: the ratio of vulnerability to tradecraft is one to ten, and it tells you how much of this campaign patching actually addresses.

01



### RESOURCE DEVELOPMENT

## Anonymise before touching anything

T1583

Acquire Infrastructure — routes operator traffic through commercial VPNs such as [ProtonVPN](#), so the scanning and the intrusion do not trace back.

↓ *anonymised, they sweep for the unpatched edge*

02



### INITIAL ACCESS

## Read the credentials off the VPN appliance

T1190

Exploit Public-Facing Application — path traversal against the FortiOS SSL VPN portal retrieves system files without authenticating, and the credentials inside are then used to connect as a real user.

[via CVE-2018-13379](#)

T1190

Exploit Public-Facing Application — SQL injection against internet-facing web applications, the second documented route in and the reason patching FortiOS alone does not close the door.

↓ The vulnerability's contribution ends here — it delivered a working login and nothing more. Everything below is Agrius's own tradecraft and would follow identically from the SQL injection route, from stolen credentials, or from any other foothold.

03



### EXECUTION

## Run commands through a web shell

T1059.003

Windows Command Shell — [ASPXSpy](#) web shells relay operator input to [cmd.exe](#) on the compromised server.

↓ a stolen login can be revoked — the next step cannot

04



## PERSISTENCE

### Lock in the foothold

- T1505.003** Web Shell — plants multiple `ASPXSpy` variants as durable re-entry points.
- T1543.003** Windows Service — registers the `IPsec Helper` backdoor as a service that auto-starts.

↓ durable access still has to look unremarkable

05



## STEALTH

### Disguise the operation

- T1036** Masquerading — renames the Plink tunnelling tool to `systems.exe` to blend with system binaries.
- T1140** Deobfuscate/Decode — deploys base64-encoded ASPXSpy variants to slip past signatures.
- T1078.002** Domain Accounts — reuses valid domain credentials so activity reads as legitimate.

↓ blending in is not enough — next they break the sensors outright

06



## DEFENSE IMPAIRMENT

### Kill the security stack

- T1685** Disable or Modify Tools — loads the vulnerable `GMER64.sys` driver to terminate EDR and antivirus services from kernel mode.

↓ with EDR blinded, they harvest credentials unobserved

07



## CREDENTIAL ACCESS

### Steal the keys to the domain

- T1003.001** LSASS Memory — `Mimikatz` dumps plaintext and hashed credentials from memory.
- T1003.002** Security Account Manager — extracts the local `SAM` hive.
- T1110.003** Password Spraying — sprays credentials over SMB to reach more hosts.

↓ *credentials in hand, they map the network*

08



## DISCOVERY

### Chart the internal terrain

**T1046** Network Service Discovery — scans hosts and services with the [WinEggDrop](#) port scanner.

**T1018** Remote System Discovery — enumerates reachable hosts with [NBTscan](#).

↓ *mapped targets become movement destinations*

09



## LATERAL MOVEMENT

### Spread to high-value hosts

**T1021.001** Remote Desktop Protocol — tunnels RDP through web shells and [Plink](#) to pivot deeper.

**T1570** Lateral Tool Transfer — pulls payloads from file-sharing sites ( [ufile.io](#) , [easyupload.io](#) ).

↓ *on the crown-jewel servers, they collect before they destroy*

10



## COLLECTION

### Gather and stage the goods

**T1119** Automated Collection — custom [sql.net4.exe](#) queries SQL databases for PII.

**T1005** Data from Local System — pulls files from databases and critical servers.

**T1560.001** Archive via Utility — compresses the haul with [7zip](#).

**T1074.001** Local Data Staging — parks archives in [C:\windows\temp\s\](#) before exfil.

↓ *staged data leaves over the operator's own channel*

11



## EXFILTRATION

### Ship the data out

**T1041** Exfiltration Over C2 Channel — moves the staged archives out using [PuTTY](#) and [WinSCP](#).

↓ *with data secured, the real objective executes*



## IMPACT — THE OBJECTIVE

# Destroy the environment

Everything above exists to reach this. Agrius detonates **wipers disguised as ransomware**: victims see a ransom note, but the data is already unrecoverable. Destruction, not payment, is the goal — which is why the entry vector mattered so little to them and the dwell time mattered so much.

Wiper

Apostle , DEADWOOD , MultiLayer Wiper and BFG Agonizer overwrite and corrupt data.

Ransom

Moneybird provides ransomware cover for the destructive intent.



Tactic icon and label warm as the intrusion advances



The spine tracks the same progression

T####

ATT&CK technique ID

via CVE

Enabled by the vulnerability — absent below the handoff

tool.exe

Observed tooling / IOC

## Named software behind the campaign

Note the split: the access and credential tooling is commodity, and the destructive tooling is bespoke. That is where a wiper crew spends its development budget.

### ASPXSpy

S0073

ASP.NET web shell — execution and persistence foothold.

**WEB SHELL**

### IPsec Helper

S1132

Post-exploitation remote-access framework run as a service.

**BACKDOOR**

### Mimikatz

S0002

Credential dumping from LSASS memory.

**CRED ACCESS**

### NBTscan

S0590

NetBIOS scanner for remote-host discovery.

**DISCOVERY**

### Apostle

S1133

Wiper masquerading as ransomware.

**WIPER**

### DEADWOOD

S1134

Standalone data-destruction wiper.

**WIPER**

### MultiLayer Wiper

S1135

Multi-stage file-destruction tool.

**WIPER**

### BFG Agonizer

S1136

Wiper used in later destructive operations.

**WIPER**

### Moneybird

S1137

Ransomware providing cover for destruction.

**RANSOMWARE**



# Close the door, then assume it was used

The patch is trivial and seven years old. The harder work is the assumption that follows it — because this flaw leaks credentials, patching does not invalidate what was already taken.

## Patch FortiOS and FortiProxy

FortiOS 5.4.13+ , 5.6.8+ or 6.0.5+ ; FortiProxy 1.2.9+ . Anything still on an affected build in 2026 should be treated as compromised rather than merely vulnerable.

PATCH

## Rotate every VPN credential

The vulnerability discloses credentials, so patching stops future theft but does nothing about what already leaked. Reset all SSL VPN account passwords and enforce MFA — a stolen password is worthless against a second factor.

CREDENTIALS

## Hunt below the handoff

Look for ASPXSpy artefacts on web-facing servers, GMER64.sys or unexpected driver loads, Plink renamed to systems.exe , and staging in C:\windows\temp\s\ . Patching closes the door; it does not remove anyone already through it.

HUNT

| CVE            | CVSS | AFFECTED                                                                                                 | FIXED IN                                          |
|----------------|------|----------------------------------------------------------------------------------------------------------|---------------------------------------------------|
| CVE-2018-13379 | 9.8  | FortiOS 5.4.6–5.4.12, 5.6.3–5.6.7, 6.0.0–6.0.4 · FortiProxy 1.0.0–1.0.7, 1.1.0–1.1.6, 1.2.0–1.2.8, 2.0.0 | FortiOS 5.4.13 / 5.6.8 / 6.0.5 · FortiProxy 1.2.9 |

## What this mapping is built on

- 1 MITRE ATT&CK — Groups: Agrius (G1030) — <https://attack.mitre.org/groups/G1030/>
- 2 NVD — CVE-2018-13379 (FortiOS SSL VPN path traversal) — <https://nvd.nist.gov/vuln/detail/CVE-2018-13379>

CVSS, CWE, affected and fixed versions verified against NVD; techniques and software taken from the published G1030 mapping.

**Attribution confidence — high, and published.** The link between Agrius and CVE-2018-13379 is not inferred here. MITRE's own G1030 entry for T1190 names the CVE directly, and names SQL injection alongside it as a second route. Both are given as *examples*, so treat the two documented vectors as a floor rather than a complete list of how this actor gets in.

**Scope note.** This is a campaign view: Agrius read through one entry vector, for a reader who owns Fortinet appliances and needs to know what patching achieves. The full technique set is here rather than split across a separate actor profile, because Agrius has a documented CVE and the tradecraft does not change with the door — a campaign report is the correct single home for both halves. CVE-2018-13379 is widely exploited by many actors; patch it because it is exposed, not because of who is on this page.